UNIT 5 · TOPIC 5.3

Symmetric Encryption, Hashing and Key Storage

Quiz

Instructions: This quiz has 18 multiple-choice questions, 1 point each. Circle the letter of the single best answer for each question.

Name: **Date:** **Class:**

1. Which of the following is an example of a security control that protects data at rest?

- ○ A. Full-disk encryption applied to a laptop hard drive
- ○ B. Firewall rules that filter inbound network traffic
- ○ C. An intrusion detection system that monitors network packets
- ○ D. A VPN tunnel established between two branch offices

2. Which of the following best describes the defining characteristic of a symmetric encryption algorithm?

- ○ A. It uses one key to encrypt data and a mathematically related but different key to decrypt it
- ○ B. It produces a fixed-length digest from input data and cannot be reversed
- ○ C. It uses the same key to both encrypt and decrypt data
- ○ D. It distributes encrypted data across multiple servers so no single server holds a complete copy

3. A security analyst wants to verify that a stored configuration file has not been altered since it was last saved by an authorized administrator. Which cryptographic control is most appropriate for this specific purpose?

- ○ A. AES-256 symmetric encryption of the file
- ○ B. A digital certificate issued to the administrator
- ○ C. A cryptographic hash of the file stored separately in a secure location
- ○ D. A symmetric decryption key held by the administrator

4. A company stores customer payment records on an internal server. An employee's laptop containing a local copy of these records is stolen from a vehicle. The IT team confirms the laptop's hard drive was encrypted with AES-256. Which statement best explains how this control mitigates the risk of data exposure?

- ○ A. AES-256 prevents the thief from connecting the laptop to any external network, isolating the data
- ○ B. The encryption ensures the data was backed up to a secure server immediately before the theft occurred
- ○ C. AES-256 encryption automatically triggers a remote data wipe once the laptop is reported stolen
- ○ D. Without the correct decryption key, the ciphertext on the stolen drive is computationally infeasible to recover in any useful timeframe

5. A database administrator hashes all stored user passwords using SHA-256. A security auditor inspects the database and finds that two user accounts with the same password produce identical hash values. Which additional control would eliminate this vulnerability, and why does it work?

- ○ A. Add a unique, randomly generated salt to each password before hashing, so identical passwords produce different hash outputs
- ○ B. Encrypt each stored hash value with AES-256 to prevent the auditor from reading the database
- ○ C. Replace SHA-256 with AES-256, since AES is a stronger algorithm for storing passwords
- ○ D. Store the original plaintext passwords alongside their hashes to allow the administrator to verify correctness manually

6. A developer must choose between AES-128 and AES-256 for encrypting sensitive health records. Which option provides stronger security, and which property of the algorithm accounts for the difference?

- ○ A. AES-128 is stronger because a shorter key is processed through more internal rounds, compressing the output more securely
- ○ B. AES-256 is stronger because its longer key exponentially increases the number of possible key values, making brute-force attacks significantly harder
- ○ C. AES-128 and AES-256 are equally secure because both use the same 128-bit block size for data processing
- ○ D. AES-256 is stronger because it stores twice as many data blocks per operation, reducing the number of encryption passes needed

7. A data classification policy requires that files labelled "Confidential" satisfy two independent security requirements: (1) their contents must be unreadable if the storage media is seized, and (2) any unauthorised modification to the file must be detectable before the file is used. Which combination of cryptographic controls best satisfies both requirements simultaneously?

- ○ A. Full-disk encryption with AES-256 only
- ○ B. SHA-256 hashing of each file, with hashes stored in a secure registry
- ○ C. AES-256 encryption of each file combined with a SHA-256 hash of the plaintext stored in a separate access-controlled registry
- ○ D. Triple-DES encryption applied in two passes to each file

8. An organisation uses AES in ECB (Electronic Codebook) mode to encrypt a large bitmap image file for archival storage. A forensic analyst examining the encrypted file observes that regions of the ciphertext correspond visually to structural outlines of the original image. Which evaluation of this implementation is most accurate?

- ○ A. ECB mode is secure for image files because each block is encrypted independently, preventing any one block from leaking information about neighbouring blocks
- ○ B. ECB mode is insecure for this use case because identical plaintext blocks produce identical ciphertext blocks, allowing patterns in the data to remain visible in the encrypted output
- ○ C. The pattern leakage indicates that the key length was insufficient for the size of the image file being encrypted
- ○ D. The vulnerability exists because AES operates as a hash function on binary data and cannot fully conceal structural information in large files

9. A development team stores encrypted configuration files containing API keys on a shared internal server. They implement AES-128-CBC and embed the encryption key as a string constant in the application's source code, which is hosted in a public GitHub repository. Evaluate the security posture of this implementation and identify the primary point of failure.

- ○ A. The primary weakness is AES-128; upgrading to AES-256 would make the implementation secure
- ○ B. The primary weakness is the use of CBC mode; switching to ECB would eliminate the vulnerability introduced by IV management
- ○ C. The implementation is secure because the key is embedded in compiled application code and cannot be extracted through the repository alone
- ○ D. The primary weakness is the hard-coded key committed to a public repository; an attacker who clones the repository can decrypt every protected file regardless of algorithm strength

10. When implementing symmetric file encryption, which item must be securely stored and protected to allow authorised decryption of the file in the future?

- ○ A. The plaintext version of the file, archived before encryption
- ○ B. The name of the encryption algorithm used

○ C. The symmetric key used during the encryption operation

○ D. The original file size in bytes before encryption was applied

11. A technician encrypts a sensitive report file using AES-256 from the command line. After the operation completes, the original unencrypted file remains on disk alongside the new encrypted version. What additional implementation step is required to complete data protection?

○ A. Securely delete the original plaintext file so that it cannot be recovered from disk

○ B. Re-encrypt the original file a second time using a different algorithm to add a second layer of protection

○ C. Share the encryption key with all team members to ensure redundant access to the data

○ D. Convert the encrypted file to a compressed archive format to improve storage efficiency

12. Which of the following most accurately describes what happens during a symmetric key encryption operation on a file?

○ A. The file is split into two halves; each half is encrypted independently using a different portion of the key

○ B. The file is uploaded to a cloud provider, which applies server-side encryption on the organisation's behalf

○ C. The file is compressed into a smaller format and transmitted over a secure channel to a remote server

○ D. The file's contents are processed by the encryption algorithm together with the secret key to produce a ciphertext output

13. A developer implements AES-CBC encryption for a file storage application. She generates a random Initialization Vector (IV) for the first file encrypted, then reuses that same IV for every subsequent file encrypted with the same key. Which specific security problem does IV reuse introduce in CBC mode?

○ A. Reusing an IV causes the encryption process to run faster, which creates a timing channel that an attacker can exploit

○ B. Reusing an IV with the same key means that an attacker who knows the plaintext of one file may be able to infer information about the plaintext of other files encrypted with the same IV and key pair

○ C. The IV is a secret value; reusing it publicly exposes it to any observer of the ciphertext, directly compromising the encryption key

○ D. Reusing an IV causes decryption to fail, so the encrypted files cannot be recovered at all

14. An organisation needs to encrypt a large database of structured records at rest and must choose between AES-ECB mode and AES-GCM mode. Apply your understanding of encryption modes to determine which is more appropriate and justify the selection.

○ A. AES-ECB is more appropriate; its simpler implementation provides the same confidentiality guarantees as GCM without the overhead of managing nonces

○ B. AES-GCM is more appropriate only when data is transmitted over a network; for data stored at rest, AES-ECB provides equivalent protection

○ C. AES-ECB is more appropriate; GCM mode cannot process files larger than 64 KB without splitting them into separate encryption streams

○ D. AES-GCM is more appropriate; it provides both confidentiality and authenticated integrity in a single operation, and avoids the pattern-leakage problem that affects ECB mode

15. A security engineer uses an AI-powered code assistant to generate a Python function that encrypts user files with AES-128-CBC. The AI-generated code is functional but initialises the IV as a fixed sequence of 16 zero bytes for every encryption call. Which implementation detail must the engineer correct before deployment, and why?

○ A. Replace the IV with the user's hashed password to make the encryption personalised to each user

○ B. Store the fixed IV in an encrypted configuration file alongside the key so that it is protected from disclosure

○ C. Replace the fixed IV with a securely generated random IV for each individual encryption operation, ensuring ciphertext unpredictability across calls

○ D. No correction is needed; the value of the IV does not affect the confidentiality provided by AES-CBC

16. A development team documents the following implementation steps for their file encryption module:

Step 1, Derive the AES-256 key: key = MD5(user_password)

Step 2, Encrypt the file using AES-256-CBC with the derived key

Step 3, Append the IV to the beginning of the ciphertext output file

Step 4, Overwrite and delete the original plaintext file

Evaluate the implementation and identify the most critical security flaw.

○ A. Step 1 is flawed; MD5 is a fast, cryptographically broken hash function that is unsuitable as a key derivation function, a purpose-built KDF such as PBKDF2 or Argon2 with appropriate iteration count should replace it

○ B. Step 3 is flawed; storing the IV in the output file exposes it to any attacker who accesses the ciphertext

○ C. Step 4 is flawed; the plaintext file should be archived in a separate secure location before deletion in case the key is lost

○ D. Step 2 is flawed; AES-256-CBC is not approved for file encryption by current NIST guidelines and must be replaced with a compliant algorithm

17. A medical records application must satisfy three requirements for data stored on its servers: (a) encrypted data cannot be decrypted without authorised credentials, (b) any tampering with ciphertext stored on disk is detectable before the data is used, and (c) all encryption and decryption events must be auditable. Design the mitigation strategy that most completely addresses all three requirements, and identify which component satisfies each.

○ A. Use AES-256-ECB for (a), store a separate SHA-256 checksum of each encrypted file for (b), and enable OS filesystem audit logging for (c)

○ B. Use AES-256-GCM for (a) and (b) simultaneously, GCM's authentication tag detects ciphertext tampering, and implement application-level structured logging of all encrypt/decrypt calls with timestamps and operator identity for (c)

○ C. Use SHA-256 hashing for (a), AES-128-CBC for (b), and store all audit logs encrypted with the same key used for the records for (c)

○ D. Use AES-256-CBC for (a), configure firewall rules to block unauthorised write access to the database for (b), and conduct quarterly manual reviews of access logs for (c)

18. An organisation deploys an AI-assisted security tool that automatically recommends encryption settings for new file storage systems. For a new internal archive containing financial records, the AI recommends: AES-128-CBC with an IV derived deterministically from the system hostname, and the encryption key stored as a plaintext environment variable readable by all application processes on the host. A security engineer must evaluate the AI's recommendation and implement a corrected version. Which corrected implementation is most appropriate?

○ A. Accept the AI's recommendation but add a second AES-128-CBC encryption pass with a different deterministic IV to increase the number of encryption layers

○ B. Replace AES-128-CBC with a stream cipher, since stream ciphers are not affected by IV reuse and eliminate the IV management problem entirely

○ C. Use AES-128-ECB to eliminate IV management complexity while retaining AES compatibility with existing tooling

○ D. Use AES-256-GCM with a unique randomly generated nonce per encryption operation, store the encryption key in a dedicated secrets manager with role-based access control, and log all key retrieval events to an append-only audit trail